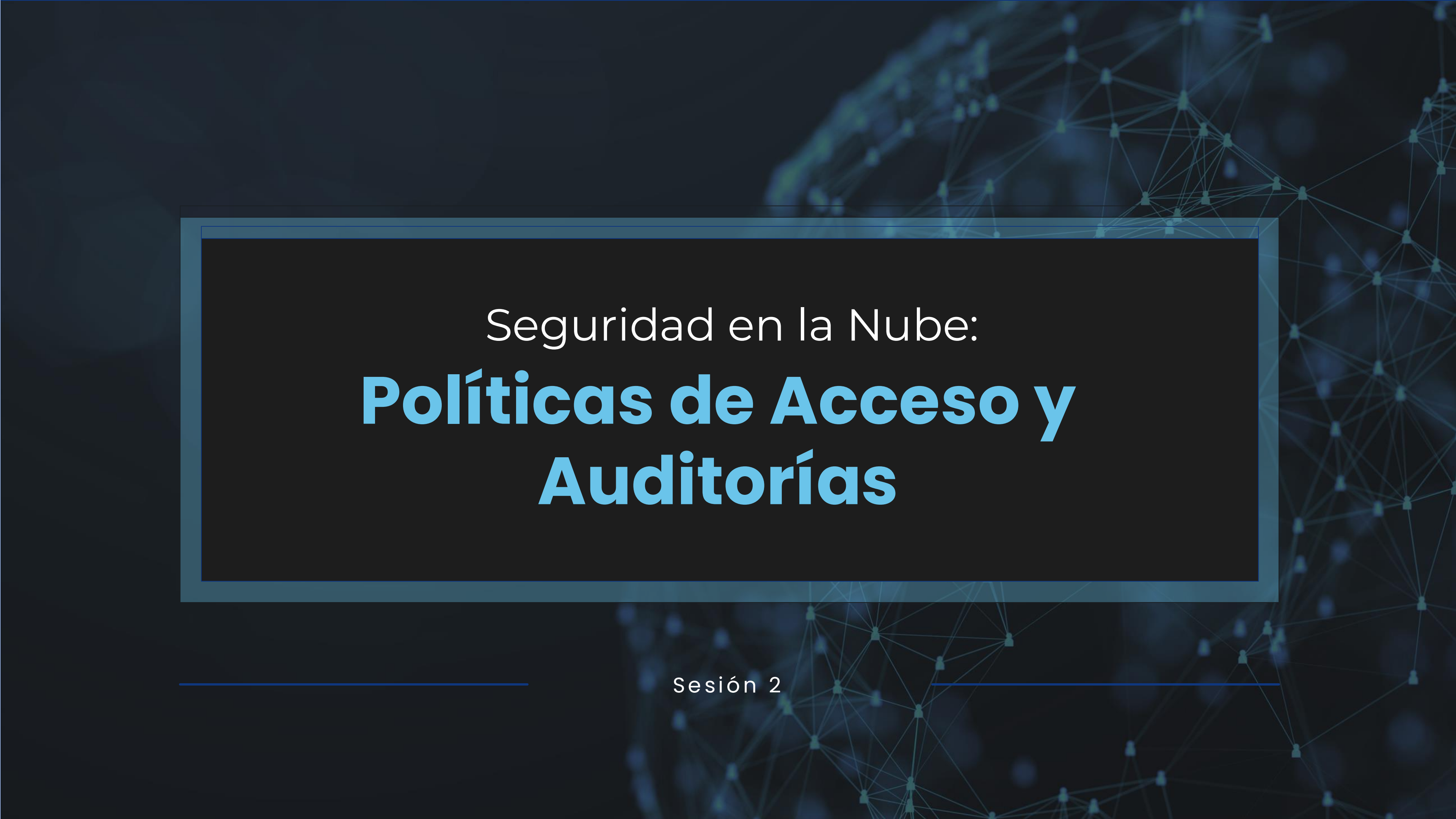


The background of the slide features a complex network diagram with numerous nodes and connecting lines, rendered in a light blue color against a dark blue background. The diagram is more prominent in the upper right and lower right areas.

Seguridad en la Nube: **Políticas de Acceso y Auditorías**

Sesión 2

Agenda

- 1.Introducción a RBAC y ABAC
- 2.Herramientas: Simulador de políticas de AWS IAM
- 3.Creación de Políticas JSON
- 4.Principio de Privilegio Mínimo
- 5.Auditorías y Revisiones Periódicas
- 6.Casos prácticos y ejemplos

RBAC vs. ABAC

RBAC (Control de acceso basado en roles)

- **Definición:** Asignar permisos a roles, no a usuarios directamente.
- **Ejemplo:** Rol "Desarrollador" con acceso a S3 y EC2.
- **Ventaja:** Sencillo, escalable para equipos grandes.

ABAC (Control de acceso basado en atributos)

- **Definición:** Permisos dinámicos basados en atributos (ubicación, departamento).
- **Ejemplo:** Acceso a S3 solo desde IP autorizadas.
- **Ventaja:** Granularidad fina y adaptable.

CRITERIO	RBAC	ABAC
Granularidad	Roles	Atributos
Escalabilidad	Medios de comunicación	Alta
Complejidad	Baja	Alta

Simulador de políticas de AWS IAM

¿Qué es?

- Herramienta para probar políticas de acceso **sin afectar entornos reales**.

Funcionalidades Clave:

1. Permisos de usuarios/roles similares.
2. Probar condiciones (IP, MFA, etiquetas).
3. Comparar versiones de políticas.

Pasos básicos:

1. Seleccionar usuario/rol.
2. Cargar política JSON.
3. Definir acción y recurso.
4. Ejecutar simulación.

Ejemplo:

- ¿Puede el rol listar objetos en? `analista-datos` `ventas-2024`

Estructura de una Política JSON

Elementos Clave:

```
1 {  
2   "Version": "2012-10-17",  
3   "Statement": [  
4     {  
5       "Effect": "Allow",  
6       "Action": ["s3:GetObject"],  
7       "Resource": "arn:aws:s3:::mi-bucket/*",  
8       "Condition": {  
9         "IpAddress": { "aws:SourceIp": "203.0.113.0/24" }  
10      }  
11    }  
12  ]  
13 }
```

Mejores Prácticas:

- **Privilegio mínimo:** Solo acciones necesarias.
- **Evitar :** `"Resource": "*"` Especificar ARNs.
- **Usar condiciones:** IP, MFA, etiquetas.

Principio de Privilegio Mínimo

"Solo los permisos estrictamente necesarios".

Ejemplo:

- Un desarrollador no debe tener permisos para eliminar instancias EC2 si solo necesita implementar aplicaciones.

Pasos para aplicarlo:

1. Revisar los actuales estatutos.
2. Eliminar acciones no usadas (ej:).
3. Aplicar condiciones (IP, MFA).
4. Priorizar sobre conflictos.

`ec2:TerminateInstances`

`Deny` : `Allow`

Herramientas:

- Analizador de acceso de AWS IAM.
- Configuración de AWS.

Auditorías y Revisiones

Objetivos:

- Identificar permisos redundantes.
- Cumplir normativas (ISO 27001, RGPD).

Herramientas Clave:

1. **AWS CloudTrail:** Registra la actividad de los usuarios.
2. **AWS Config:** Detecta políticas inseguras.
3. **IAM Access Analyzer:** Alertas de permisos excesivos.

Lista de verificación de Auditoría:

- ¿Hay políticas con ? `Action": "*"`
- ¿Usuarios ¿Acceso a recursos críticos sin MFA?
- con claves API inactivas >90 días?

Caso Práctico – Corrección de Política

Antes (Asegura):

```
1 {  
2   "Version": "2012-10-17",  
3   "Statement": [  
4     {  
5       "Effect": "Allow",  
6       "Action": "s3:*",  
7       "Resource": "*" }  
9   ]  
10 }
```

Después (Corregida):

```
1 {  
2   "Version": "2012-10-17",  
3   "Statement": [  
4     {  
5       "Effect": "Allow",  
6       "Action": ["s3:GetObject", "s3:ListBucket"],  
7       "Resource": ["arn:aws:s3:::ventas-2024", "arn:aws:s3:::ventas-2024/*"],  
8       "Condition": { "IpAddress": { "aws:SourceIp": "203.0.113.0/24" } }  
9     }  
10  ]  
11 }
```

Problemas:

- Permite eliminar cubos.
- Aplicar a todos los recursos.

Actividades para la Clase

1. Ejercicio 1: Crear una política JSON para un rol de "Analista de Datos" con acceso de lectura a un bucket S3 específico.

2. Ejercicio 2: Usar el AWS IAM Policy Simulator para probar la política anterior.

3. Discusión: ¿Cómo aplicar ABAC en una empresa con múltiples departamentos?

Conclusión y Preguntas

Resumen:

- RBAC y ABAC son complementarios.
- El Simulador de Políticas reduce los riesgos.
- El privilegio mínimo es clave para la seguridad.

Preguntas frecuentes:

- ¿Cómo equilibrar seguridad y flexibilidad en políticas?
- ¿Qué herramientas recomiendan para auditorías automatizadas?

Referencias:

- Documentación AWS IAM.
- NIST SP 800-53 (Privilegio Mínimo).